

Lab - Social Engineering

Objectives

Research and identify social engineering attacks

Background / Scenario

Social engineering is an attack with the goal of getting a victim to enter personal or sensitive information, this type of attack can be performed by an attacker utilizing a keylogger, phishing email, or an in-person method. This lab requires the research of social engineering and the identification of ways to recognize and prevent it.

Required Resources

- PC or mobile device with internet access

Instructions

Using a web browser find the article “Methods for Understanding and Reducing Social Engineering Attacks” on the SANS Institute website. A search engine should easily find the article.

The SANS Institute is a cooperative research and education organization that offers information security training and security certification. The SANS Reading Room has many articles that are relevant to the practice of cybersecurity analysis. You can join the SANS community by creating a free user account in order to access to the latest articles, or you can access the older articles without a user account.

Read the article or choose another article on social engineering, read it, and answer the following questions:

a. What are the three methods used in social engineering to gain access to information?

- **Trực tiếp / Trực diện (In-person / Physical).**
- **Qua điện thoại / Gián tiếp (Over the phone / Remote).**
- **Qua Internet / Email (Online / Email).**

b. What are three examples of social engineering attacks from the first two methods in step 2a?

- **Phishing (Email lừa đảo): Gửi email giả danh tổ chức uy tín để dụ nạn nhân nhấp vào liên kết độc hại hoặc cung cấp mật khẩu.**
- **Pretexting (Tạo kịch bản giả): Kẻ tấn công gọi điện giả làm nhân viên hỗ trợ IT để yêu cầu người dùng cung cấp thông tin đăng nhập.**
- **Tailgating (Bám đuôi): Kẻ tấn công đi ngay sau nhân viên hợp pháp để lén vào khu vực hạn chế mà không cần quẹt thẻ.**

c. Why is social networking a social engineering threat?

Người dùng thường chia sẻ quá nhiều thông tin cá nhân (ngày sinh, vị trí, mối quan hệ, thói quen), giúp kẻ tấn công dễ dàng thu thập dữ liệu để xây dựng kịch bản lừa đảo chính xác và đáng tin cậy.

d. How can an organization defend itself from social engineering attacks?

- **Đào tạo nhận thức: Nâng cao nhận thức bảo mật định kỳ cho nhân viên.**
- **Chính sách an toàn: Thiết lập quy trình xác minh danh tính rõ ràng và chính sách quản lý truy cập nghiêm ngặt.**
- **Xác thực nhiều yếu tố (MFA): Bắt buộc dùng MFA để bảo vệ tài khoản ngay cả khi lộ mật khẩu.**

e. What is the SANS Institute, which authored this article?

SANS Institute là một tổ chức nghiên cứu và giáo dục hợp tác chuyên cung cấp các chương trình đào tạo và chứng chỉ về an toàn thông tin.